APIGUARD — Continuous API Security Assessment in DevSecOps Pipelines

Rule scanning stays authoritative; the model ranks every endpoint and explains why

RUNTIME · in the pipeline

OpenAPI spec
OpenAPI 3.x / Swagger 2.0

S0 Normaliser
parse to one internal form

S1 Rule scanner
Spectral + OWASP ruleset (2023)

S2 AI verifier
- **S2a** Feature builder
- **S2b** XGBoost
- **S2c** SHAP

S3 Risk gate
score vs threshold τ

pass → exit 0
fail → exit 1

identical code path

loaded at startup

OFFLINE · training

T1 Corpus
APIs.guru, APIstic

T2 Labels
scanner + LLM labels + vulnerable apps

T3 Shared core
same S0 + S2a code as runtime

T4 Trainer
grouped splits, fixed seeds

model.json
trained artefact

retraining is run deliberately, never automatically

no arrow from the gate back into the model — that would train it on its own output

FEEDBACK · human review

Feedback queue
feedback.jsonl

Developer / analyst
reviews the verdict

shared code and model artefact (dashed = identical code path)

human-in-the-loop path

Unit of analysis: one endpoint (path + method)